

Phishing Incident Analysis Report

Evidence-led assessment of message authenticity, attack surface, and human factors

CASE ID

PF-39BC4CB5

OVERALL SEVERITY

26/100

CVSS BASE SCORE

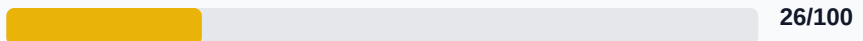
6.9

Generated 14/9/2026, 6:31:06 pm

Classification: Medium

CVSS 3.1 vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:N

COMPOSITE SEVERITY



1. Executive Summary

This report documents the analysis of a phishing email purportedly from "it-support@company-secure-verify.example.com". The message content employed 5 distinct social-engineering tactic(s), including Urgency / Time Pressure, Authority Impersonation, Fear / Threat of Loss, Credential Harvesting Request, Generic / Non-Personalized Greeting. Of 4 employee(s) assessed, 50% took a compromising action (credential entry and/or attachment execution). Overall composite severity is scored 26/100, corresponding to a CVSS 3.1 base score of 6.9.

2. Email Header & Authentication Analysis

Identity:

From: it-support@company-secure-verify.example.com

Reply-To: no-reply@mail-relay.example.net

Return-Path: bounce@mail-delivery.example.net

Subject: URGENT: Your account will be suspended within 24 hours - Immediate Verification Required

Authentication Results:

SPF: none | DKIM: none | DMARC: none

Findings:

[LOW] No SPF record evaluation found in headers — could not verify sender authorization.

[LOW] No DKIM signature present — message authenticity cannot be cryptographically verified.

[HIGH] From domain (company-secure-verify.example.com) differs from Reply-To domain (mail-relay.example.net). Classic BEC/phishing technique to redirect victim replies to an attacker-controlled mailbox.

[MEDIUM] From domain (company-secure-verify.example.com) differs from envelope Return-Path domain (mail-delivery.example.net).

[MEDIUM] Only a single mail hop detected. Legitimate corporate mail typically transits multiple relays; a single hop can indicate direct injection from a script or open relay.

Header Risk Score: 18/100

3. Malicious Link & QR Code Analysis

1. <https://account-verify.company-secure-verify.example.com/login>

Verdict: LIKELY_BENIGN | Score: 18/100

[LOW] Domain contains an unusually high number of hyphens, a common typosquatting pattern.

[LOW] Unusually long domain name, often used to bury a real brand name inside a longer malicious string.

5. Content & NLP / Persuasion-Tactic Analysis

Detected tactics (mapped to Cialdini's principles of influence):

- **Urgency / Time Pressure** — Principle: Scarcity, matches: 3
- **Authority Impersonation** — Principle: Authority, matches: 2
- **Fear / Threat of Loss** — Principle: Loss Aversion / Fear, matches: 1
- **Credential Harvesting Request** — Principle: N/A (technical intent), matches: 1
- **Generic / Non-Personalized Greeting** — Principle: N/A (quality signal), matches: 1

Content Risk Score: 60/100

6. Composite Severity Breakdown



CVSS 3.1 Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:N
CVSS Base Score: 6.9 (Medium)

7. Standards Mapping — OWASP Top 10 & MITRE ATT&CK

OWASP Top 10 (2021) Relevance:

A01:2021 — Broken Access Control

If harvested credentials grant the attacker unauthorized access to systems the victim was authorized to use.

A03:2021 — Injection

Relevant if the phishing payload leads to script/macro injection via the attachment.

A05:2021 — Security Misconfiguration

Relevant where SPF/DKIM/DMARC were absent or misconfigured, enabling spoofing.

A07:2021 — Identification and Authentication Failures

Directly relevant when credentials were harvested and MFA was absent or bypassed.

A09:2021 — Security Logging and Monitoring Failures

Relevant if the phishing email or resulting compromise was not detected by existing monitoring.

MITRE ATT&CK Techniques Observed:

T1566 — Phishing (Tactic: Initial Access)

T1566.001 — Spearphishing Attachment (Tactic: Initial Access)

T1566.002 — Spearphishing Link (Tactic: Initial Access)

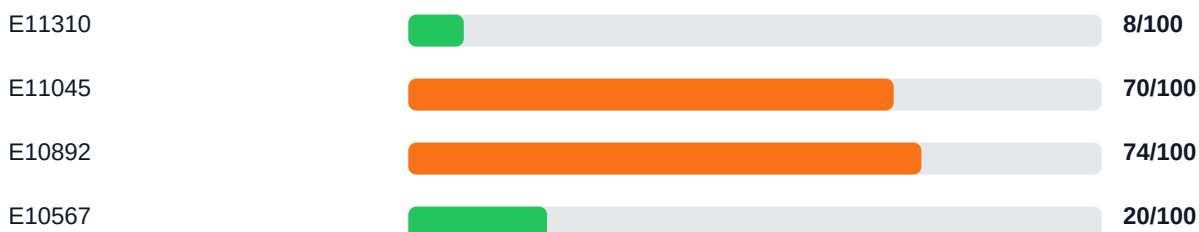
T1598 — Phishing for Information (Tactic: Reconnaissance)

T1204 — User Execution (Tactic: Execution)

T1656 — Impersonation (Tactic: Resource Development / Defense Evasion)

8. Forensic & Psychological Analysis (Per-Employee)

Note: This section identifies which social-engineering mechanisms the questionnaire responses indicate were effective. It is a behavioral/pattern analysis for security-training purposes, not a clinical or diagnostic assessment of any individual.



Employee: E11310 | Dept: Engineering | Tier: Low Susceptibility

20-question average: 1.6/5

[MEDIUM] Employee acted on an email they were not expecting, without independent verification through a second channel.

[INFO] Employee's response aligns with the "authority" social-engineering trigger (rated 0/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "curiosity" social-engineering trigger (rated 3/5), consistent with the manipulation tactics identified in the content analysis.

Recommended follow-up:

- No corrective action required — reinforce positive reporting behavior with recognition.

Employee: E11045 | Dept: Sales | Tier: High Susceptibility

20-question average: 2.15/5

[CRITICAL] Employee entered credentials on the phishing page — direct account compromise risk.

[HIGH] Employee reported feeling time pressure, indicating the urgency/scarcity tactic in the email was effective (Cialdini: Scarcity).

[MEDIUM] Employee acted on an email they were not expecting, without independent verification through a second channel.

[HIGH] Employee did not report the incident to security, delaying containment and increasing organizational dwell-time risk.

[INFO] Employee's response aligns with the "authority" social-engineering trigger (rated 1/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "urgency" social-engineering trigger (rated 5/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "fear" social-engineering trigger (rated 5/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "fatigue" social-engineering trigger (rated 4/5), consistent with the manipulation tactics identified in the content analysis.

Recommended follow-up:

- Immediate password reset + force re-authentication with MFA enrollment check.
- Enroll in targeted phishing-simulation micro-training within 2 weeks.
- Coach on the 'report first, don't investigate yourself' reporting policy.

Employee: E10892 | Dept: Human Resources | Tier: High Susceptibility

20-question average: 2.1/5

[CRITICAL] Employee opened the malicious attachment, potentially triggering payload execution.

[HIGH] Employee recognized a familiar-looking sender name but did not verify the actual email address — spoofed display-name attacks exploit this exact gap.

[MEDIUM] Employee acted on an email they were not expecting, without independent verification through a second channel.

[MEDIUM] No prior completed security awareness training on record for this employee — a contributing organizational (not individual) factor.

[MEDIUM] Incident was reported 240 minutes after the interaction, extending the window for attacker follow-through.

[INFO] Employee's response aligns with the "authority" social-engineering trigger (rated 3/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "trust" social-engineering trigger (rated 5/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "curiosity" social-engineering trigger (rated 4/5), consistent with the manipulation tactics identified in the content analysis.

[INFO] Employee's response aligns with the "fatigue" social-engineering trigger (rated 3/5), consistent with the manipulation tactics identified in the content analysis.

Recommended follow-up:

- Endpoint forensic triage (EDR scan, isolate host pending scan results).
- Enroll in targeted phishing-simulation micro-training within 2 weeks.
- Complete baseline security awareness training module.

Employee: E10567 | Dept: IT Support | Tier: Low Susceptibility

20-question average: 1.95/5

[HIGH] Employee reported feeling time pressure, indicating the urgency/scarcity tactic in the email was effective (Cialdini: Scarcity).

[MEDIUM] Employee acted on an email they were not expecting, without independent verification through a second channel.

[INFO] Employee's response aligns with the "urgency" social-engineering trigger (rated 3/5), consistent with the manipulation tactics identified in the content analysis.

Recommended follow-up:

- No corrective action required — reinforce positive reporting behavior with recognition.

Organization-Level Psychological Summary:

Average human-factor score: 43/100

Average questionnaire score: 1.95/5 (4 response(s) with ratings)

Click-through / compromise rate: 50%

High-susceptibility employees: 2

9. Mitigation & Security Recommendations

Technical Measures:

[CRITICAL] Publish/enforce a DMARC policy at p=reject (after a monitoring period at p=quarantine) to stop spoofed mail using your domain. (Ref: RFC 7489)

[CRITICAL] Mandate phishing-resistant MFA (FIDO2/WebAuthn) for all accounts, especially those confirmed to have entered credentials. (Ref: NIST SP 800-63B / OWASP A07:2021)

[HIGH] Enforce SPF with a hard-fail policy (-all) on all sending domains. (Ref: RFC 7208 / NIST SP 800-177)

[HIGH] Deploy/repair DKIM signing on outbound mail infrastructure and rotate keys periodically. (Ref: RFC 6376)

[MEDIUM] Ensure EDR/antivirus coverage on all endpoints with real-time behavioral detection, not signature-only. (Ref: CIS Control 10)

Policy Measures:

[HIGH] Enforce immediate password rotation + session revocation for any account confirmed to have disclosed credentials.

[HIGH] Establish/reinforce a one-click 'Report Phishing' button in the mail client tied to the SOC triage queue.

[HIGH] Introduce a no-blame reporting culture policy to reduce delayed/non-reporting behavior observed in this incident.

[MEDIUM] Implement out-of-band verification requirement for any request involving credentials, payments, or urgent account actions.

Training Measures:

[HIGH] Enroll the 2 identified high-susceptibility employee(s) in focused 1:1 coaching + follow-up simulated phishing test within 30 days.

[MEDIUM] Targeted micro-training module on recognizing "Urgency / Time Pressure" tactics (principle: Scarcity).

[MEDIUM] Targeted micro-training module on recognizing "Authority Impersonation" tactics (principle: Authority).

[MEDIUM] Targeted micro-training module on recognizing "Fear / Threat of Loss" tactics (principle: Loss Aversion / Fear).

[MEDIUM] Targeted micro-training module on recognizing "Credential Harvesting Request" tactics (principle: N/A (technical intent)).

[MEDIUM] Targeted micro-training module on recognizing "Generic / Non-Personalized Greeting" tactics (principle: N/A (quality signal)).

[LOW] Run quarterly organization-wide phishing simulations with escalating sophistication, tracked against this incident's baseline click-through rate.

10. Chain of Custody — Artifact Hashes (SHA256)

Raw email source

SHA256: cd29a9061910fbd263ac80757745f7db7ad4cacf27c7a119486e96ec5c60ddca

Hashed at: 2026-09-14T13:01:05.578Z